

# Cómo analizar la protección de datos en reposo y en respaldos

**SIO0010 • Técnicas Criptográficas**

Especialización en Seguridad de la Información de las Organizaciones



**SE ENTREGA**

Al inicio de la sesión 3

Fecha: \_\_\_\_ / \_\_\_\_

**CÓMO**

En equipo de tres

Un archivo por equipo

**DEDICACIÓN**

6 horas de trabajo

independiente

**QUÉ PESA**

Parte 2 de 6 del informe

Producto • 30 % del módulo

## PUNTO DE PARTIDA

## Qué es esta entrega, y en qué cambia frente a la primera

La entrega 1 **registró** qué criptografía hay. La entrega 2 **diagnostica y recomienda**: toma dos usos del inventario —el cifrado de disco del core (hallazgo H3) y el cifrado de los respaldos (hallazgo H4)— y responde si de verdad protegen, qué está mal, y qué debería cambiar.

Es un cambio de postura importante. En el inventario estaba prohibido proponer soluciones. Aquí, en cambio, la recomendación es el objetivo. Pero se aplica una regla del oficio que vieron en la sesión 2: **recomendar solo lo que se puede sostener con una amenaza concreta y con lo que el caso permite hacer**. Una recomendación sin amenaza que la justifique, o que ignore que el contrato del core no deja tocar el esquema, no aprueba.

### LOS DOS HALLAZGOS QUE TRABAJAN, EN UNA FRASE CADA UNO

**H3** — el core tiene cifrado de disco completo, y por eso en 2019 se declaró el dato «protegido». Pero el disco solo está cifrado con el servidor **apagado**; encendido, cualquier consulta devuelve cédula, saldo y movimientos en claro, y once personas tienen acceso de lectura. **H4** — los respaldos sí se cifran, pero la llave se guarda **en el mismo directorio** que el respaldo y viaja en el mismo disco a Sabaneta.

### Lo que esta entrega no es

#### No es «cifremos todo»

Cifrar de más rompe el rendimiento y las búsquedas. La entrega dice qué cifrar, dónde y por qué; no todo lo que se pueda.

#### No es solo cambiar el algoritmo

El respaldo ya usa AES-256, que es correcto. El problema está en la llave y en el modo, no en el algoritmo.

#### No es gratis

Toda recomendación tiene una restricción del caso que la condiciona, y hay que nombrarla: el contrato del core, la ventana de mantenimiento, el presupuesto.

### Cómo repartir las seis horas

#### 1,5 h

Pieza 1: qué protege hoy cada mecanismo, con la tabla amenaza por amenaza

#### 1,5 h

Pieza 2: los tres problemas de la evidencia C y la línea corregida

#### 2 h

Pieza 3: qué datos exigen cifrado de campo, y cómo se buscarían

#### 1 h

Pieza 4: qué cuesta, qué implica, y armar el documento

## EL ENTREGABLE

## Las cuatro piezas, y qué prueba cada una

El documento tiene cuatro secciones —las mismas de la diapositiva de entrega—. Cada una demuestra que entienden algo distinto de la sesión 2.

### 1 Qué protege hoy cada mecanismo

LOS TRES ESTADOS DEL DATO

|             |                                                                                                                                        |
|-------------|----------------------------------------------------------------------------------------------------------------------------------------|
| QUÉ PIDEN   | Para el cifrado de disco (H3) y el de respaldos (H4): contra qué amenaza sirve y contra cuál no, amenaza por amenaza.                  |
| QUÉ PRUEBAN | Que distinguen los tres estados del dato —en reposo, en tránsito, en uso— y que un control puede ser real para uno e inútil para otro. |
| EL MODELO   | La tabla «Hallazgo H3 a la luz de esto» de la sesión 2. La rehacen para el disco y la repiten para el respaldo.                        |

### 2 Los tres problemas de la evidencia C

LLAVE · DERIVACIÓN · MODO

|             |                                                                                                                                                 |
|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------|
| QUÉ PIDEN   | La línea real del respaldo tiene tres problemas distintos. Identificarlos, explicarlos y escribir la línea corregida.                           |
| QUÉ PRUEBAN | Que separan tres cosas que se confunden: <b>dónde vive la llave, cómo se deriva y qué garantiza el modo</b> . Solo uno de los tres es evidente. |

### 3 Qué datos exigen cifrado de campo

Y CÓMO SE BUSCARÍAN

|             |                                                                                                                              |
|-------------|------------------------------------------------------------------------------------------------------------------------------|
| QUÉ PIDEN   | Cuáles de los datos de los 142.000 asociados exigen cifrado a nivel de campo, y por qué esos y no todos.                     |
| QUÉ PRUEBAN | Que entienden que cifrar un campo cambia cómo se busca, y que hay que resolver eso —no basta con decir «ciframos la cédula». |

### 4 Qué cuesta y qué implica

LA RESTRICCIÓN QUE MANDA

|             |                                                                                                                                                 |
|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------|
| QUÉ PIDEN   | Qué condiciona la recomendación: el contrato del core no permite cambiar el esquema sin cotización, y hay que decirlo.                          |
| QUÉ PRUEBAN | Que una recomendación de seguridad que ignora el contrato, la ventana de mantenimiento y el presupuesto no es ejecutable, y por tanto no sirve. |

## PIEZA 1 · EL MÉTODO

## Qué protege hoy cada mecanismo

La pregunta no es «¿está cifrado?», sino «¿contra qué amenaza sirve este cifrado, y contra cuál no?». Se responde con una tabla, una fila por amenaza. Este es el modelo para el **cifrado de disco del core (H3)**.

| AMENAZA                                                            | ¿EL CIFRADO DE DISCO PROTEGE? | POR QUÉ                                                                                                              |
|--------------------------------------------------------------------|-------------------------------|----------------------------------------------------------------------------------------------------------------------|
| Roban un servidor apagado del centro de datos                      | <b>Sí</b>                     | El disco está cifrado en reposo. Aquí el control hace exactamente lo que promete.                                    |
| El servidor está encendido y alguien consulta la base              | <b>No</b>                     | Con el sistema arriba, la base responde en claro. El cifrado de disco ya se «abrió» al arrancar.                     |
| Una de las once personas con acceso de lectura mira lo que no debe | <b>No</b>                     | Es acceso legítimo a la base encendida. El cifrado de disco no ve la diferencia entre una consulta buena y una mala. |
| Un atacante entra por la aplicación y llega a la base              | <b>No</b>                     | Llega por el mismo camino que una consulta normal, con la base ya descifrada.                                        |

## LA CONCLUSIÓN QUE LA TABLA DEJA SERVIDA

El cifrado de disco de Coopaburrá **protege un solo escenario**: el robo del medio físico apagado. Contra las amenazas que de verdad ocurren —consultas indebidas, insiders, intrusión por la aplicación— no aporta nada. Declararlo «protegido» en 2019 confundió **cifrado en reposo** con **protección del dato**. Esa confusión es, literalmente, el hallazgo H3.

### Y ahora repítanla para el respaldo (H4)

La misma tabla, otro mecanismo. Aquí el giro es distinto: el respaldo **sí** está cifrado con AES-256, así que contra un disco extraviado el texto cifrado aguanta... salvo que la llave viaja en el mismo disco. Una fila de ejemplo:

| El respaldo semanal que viaja a Sabaneta |                                                                                                                                                                         |
|------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Amenaza                                  | El vehículo que lleva el disco a la bodega se pierde o lo roban.                                                                                                        |
| ¿El cifrado protege?                     | <b>No, aunque el archivo esté cifrado.</b> La llave va en un archivo de texto en el mismo disco. Quien tiene el disco tiene la llave.<br><b>H4 · anexo, evidencia C</b> |
| Qué demuestra                            | Que el algoritmo estaba bien (AES-256) y aun así el dato queda expuesto, porque la <b>custodia de la llave</b> anula el cifrado.                                        |

## PIEZA 2 · EL MÉTODO

## Los tres problemas de la evidencia C

Esta es la línea real del programador de tareas de Coopaburrá. Tiene tres problemas distintos, y solo el primero salta a la vista.

```
openssl enc -aes-256-cbc -in respaldo_diario.sql -out respaldo_diario.enc \  
-k $(cat /opt/backup/llave.txt)
```

### 1 Dónde vive la llave

LO EVIDENTE

La llave está en **/opt/backup/llave.txt**, en el mismo directorio que el respaldo, y la copia semanal lleva las dos cosas en el mismo disco a Sabaneta. Cifrar y guardar la llave al lado no protege nada. **La custodia de la llave tiene que estar separada del dato que protege**, con quién la tiene y dónde con nombre y cargo.

### 2 Cómo se entrega la llave

LO QUE ESTÁ EN LA OPCIÓN

La opción **-k** minúscula **no recibe una llave: recibe una contraseña**, y la pasa por una derivación. OpenSSL mismo avisa: «deprecated key derivation used». Si el archivo ya contenía una llave aleatoria, **-k** la trata como contraseña y la **degrada**. Y hay una segunda trampa: lo que se escribe en la línea de comandos **queda visible** para cualquiera que liste los procesos con **ps** mientras el respaldo corre, cada noche entre las 11:40 y las 2:15.

### 3 Qué garantiza el modo

LO QUE NO ESTÁ

**CBC cifra, pero no autentica**. Si alguien altera el archivo de respaldo en la bodega o en el camino, al restaurarlo Coopaburrá **no se entera**: obtiene datos corruptos o manipulados sin ninguna alarma. Falta cifrado autenticado —GCM— o un HMAC que selle el cifrado. Es el mismo aprendizaje del ejercicio 2 del laboratorio.

#### LA LÍNEA CORREGIDA: QUÉ TIENE QUE LOGRAR

No hay una única respuesta, pero cualquiera válida arregla los tres: **(1)** la llave sale del directorio del respaldo y no aparece en la línea de comandos; **(2)** se usa la llave tal cual con **-K** mayúscula —o, si de verdad es una contraseña, **-pbkdf2 -iter**—; **(3)** se añade autenticación. Y una observación de nivel profesional que vale puntos: **openssl enc por sí solo no hace cifrado autenticado cómodamente**, así que lo correcto es cifrar en sobre desde la librería o con una herramienta pensada para eso. Que la herramienta elegida no sea la adecuada también es un hallazgo.

## PIEZA 3 · EL MÉTODO

## Qué datos exigen cifrado de campo

El cifrado de disco no protege la base encendida (pieza 1). La respuesta a eso es el **cifrado a nivel de campo**: cifrar el dato dentro de la tabla, para que una consulta indebida devuelva algo ilegible. Pero no todo se puede ni se debe cifrar así. Decidir cuáles es el ejercicio.

### Los dos criterios para elegir un campo

#### Sensibilidad

Qué tan grave es que ese dato se filtre. La cédula, el saldo y los movimientos de los 142.000 asociados son datos personales y financieros: alta sensibilidad. El nombre de la sucursal, no.

#### Exposición

Qué tan expuesto está hoy. Un campo que consultan a diario once personas con acceso de lectura está mucho más expuesto que uno que solo toca un proceso nocturno.

Se cifran los campos que puntúan alto en **los dos**. Querer cifrar todo a nivel de campo es la forma más rápida de que el proyecto se cancele por rendimiento, porque cada campo cifrado es un campo sobre el que ya no se puede buscar ni indexar como antes.

#### EL PROBLEMA QUE CASI TODOS OLVIDAN: ¿Y CÓMO SE BUSCA?

Si se cifra la cédula, la consulta «tráeme al asociado con cédula X» deja de funcionar, porque en la base la cédula ya no está en claro. Hay que resolverlo, y decir cómo: **búsqueda por token o índice cifrado** (se guarda un valor derivado y determinista para buscar, y el dato real cifrado aparte), **tokenización** (la cédula se reemplaza por un sustituto y la correspondencia vive en otro lugar; se verá en la sesión 6), o **cifrado en la capa de aplicación**. Una recomendación de cifrado de campo que no diga cómo se seguirá buscando está incompleta.

#### El cifrado en sobre, que hace esto administrable

|                      |                                                                                                                                                                                                                                                                    |
|----------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| La idea              | Cada campo o tabla se cifra con una llave de datos (DEK); las DEK se guardan envueltas bajo una llave maestra (KEK) en un módulo dedicado. Así rotar la llave maestra no obliga a recifrar los datos —lo verán en el laboratorio 6—.<br><b>Sesión 2 · sesión 6</b> |
| Por qué importa aquí | Es la diferencia entre «cifrar la cédula» como idea y una arquitectura que se puede operar, rotar y auditar.                                                                                                                                                       |

## PIEZA 4 · EL MÉTODO

## Qué cuesta y qué implica

Aquí es donde la mayoría de los informes de seguridad se caen: recomiendan algo impecable en el papel que la organización no puede ejecutar. Cada recomendación de las piezas 1 a 3 tiene que pasar por estas restricciones del caso.

| LA RESTRICCIÓN                                                             | QUÉ LE HACE A SU RECOMENDACIÓN                                                                                                                                                                                                        |
|----------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| El contrato del core no permite cambiar el esquema de datos sin cotización | Si su recomendación de cifrado de campo exige modificar tablas del core, no es gratis ni inmediata: puede tener que hacerse en una capa de aplicación o en un proxy, o entrar como cambio cotizado con el proveedor. Hay que decirlo. |
| La ventana de mantenimiento es de cuatro horas, domingos de 1 a 5 a.m.     | Cifrar 2,3 TB de base existente no cabe en una ventana. La migración tiene que ser por fases, y eso condiciona el plazo.                                                                                                              |
| El presupuesto de seguridad 2026 es de \$180 millones, sin destinación     | Un módulo de hardware para custodiar llaves cuesta. La recomendación compite con las otras cinco entregas por esa bolsa, así que hay que priorizar, no pedir todo.                                                                    |
| La corrección del respaldo (pieza 2) casi no cuesta                        | Cambiar la línea del respaldo y mover la llave es de las cosas más baratas y de mayor impacto del caso. Conviene señalarlo: no todo cuesta \$180 millones.                                                                            |

## LA FRASE QUE CIERRA LA ENTREGA

El comité no necesita que le digan «hay que cifrar mejor». Necesita saber, de estas recomendaciones, **cuál se hace el lunes y casi no cuesta** (la del respaldo) y **cuál es un proyecto por fases que hay que cotizar con el proveedor del core** (el cifrado de campo). Ordenar las recomendaciones por costo y viabilidad es lo que convierte un diagnóstico en algo accionable, y es el ensayo de la hoja de ruta de la entrega final.

## MÉTODO

## De dónde sale cada dato

La entrega se arma con el caso, su anexo técnico y lo que vieron en la sesión 2. Estas son las fuentes.

| FUENTE                       | QUÉ ENCUENTRAN AHÍ                                                                                                                                                           |
|------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Hallazgo H3 del caso         | Cifrado de disco confundido con protección: solo protege apagado, once personas con lectura, sin cifrado de campo. Es el insumo de las piezas 1 y 3.                         |
| Hallazgo H4 del caso         | El respaldo cifrado con la llave al lado, y la copia que viaja a Sabaneta con las dos cosas en el mismo disco. Insumo de las piezas 1 y 2.                                   |
| Evidencia C Parte 8 del caso | La línea real del respaldo. Es el texto que se audita en la pieza 2.                                                                                                         |
| Anexo técnico                | Confirma el algoritmo: el disco es <b>AES-256-XTS</b> (LUKS, Argon2id) y el respaldo <b>AES-256-CBC</b> . Así saben que el problema no es el algoritmo.                      |
| Sesión 2                     | Los tres estados del dato, ECB/CBC/CTR/GCM, el cifrado en sobre, la opción <b>-k</b> frente a <b>-K</b> , y cómo buscar sobre datos cifrados. Es el marco conceptual entero. |
| Parte 10 del caso            | Presupuesto, ventana de mantenimiento y el contrato del core. Es el insumo de la pieza 4.                                                                                    |

### UNA ADVERTENCIA SOBRE EL ALGORITMO

Es tentador recomendar «cambiar a AES-256» en el respaldo. **No hace falta: ya es AES-256.** Si su entrega propone cambiar el algoritmo del respaldo, revísenla: el problema son la llave, su custodia y la falta de autenticación, no el cifrado. Confundir eso es el error más común de esta entrega, y es el mismo que cometió Coopaburrá en 2019.

## EVALUACIÓN

## Con qué criterio se califica

Se evalúa el análisis, no la extensión. Una recomendación bien justificada y ejecutable vale más que diez impecables en el papel.

| CRITERIO                                          | PESO         | QUÉ SE MIRA                                                                                                        |
|---------------------------------------------------|--------------|--------------------------------------------------------------------------------------------------------------------|
| Amenaza por amenaza (pieza 1)                     | 25 %         | La tabla distingue contra qué sirve cada mecanismo y contra qué no. No basta decir «el cifrado de disco es débil». |
| Los tres problemas y la línea corregida (pieza 2) | 30 %         | Están los tres —llave, derivación, modo—, cada uno explicado, y la línea corregida los arregla los tres.           |
| Cifrado de campo con búsqueda resuelta (pieza 3)  | 25 %         | Se eligen campos por sensibilidad y exposición, y se dice cómo se seguirá buscando sobre ellos.                    |
| Viabilidad (pieza 4)                              | 20 %         | Cada recomendación pasa por las restricciones del caso, y quedan ordenadas por costo y factibilidad.               |
| <b>Total</b>                                      | <b>100 %</b> | <b>Parte 2 de las seis que componen el informe de aseguramiento criptográfico</b>                                  |

## LAS TRES FORMAS DE PERDER PUNTOS SIN DARSE CUENTA

**Cambiar el algoritmo.** Recomendar «pasar a AES-256» lo que ya es AES-256 delata que no se leyó el anexo.

**Recomendar sin amenaza.** «Hay que cifrar la base» sin decir contra qué amenaza y a qué costo es una opinión, no un diagnóstico. **Ignorar el contrato.** Proponer cambios en el esquema del core como si fueran gratis e inmediatos hace la recomendación inejecutable.

## Antes de entregar

- ☐ La tabla de la pieza 1 tiene **una fila por amenaza** , para el disco y para el respaldo, con «sí» o «no» y el porqué.
- ☐ Están los **tres** problemas de la evidencia C, cada uno explicado, y no confundidos entre sí.
- ☐ La **línea corregida** arregla los tres: llave fuera del respaldo y fuera de la línea de comandos, derivación correcta y autenticación.
- ☐ Los campos a cifrar se eligieron por **sensibilidad y exposición** , y se dice **cómo se buscará** sobre ellos.
- ☐ Cada recomendación nombra la **restricción del caso** que la condiciona, y quedan **ordenadas por costo** .
- ☐ No se recomienda **cambiar el algoritmo** del respaldo (ya es AES-256).
- ☐ El archivo lleva el **nombre del equipo y de sus tres integrantes** .

## PLANTILLA

## Para armar el documento

Equipo: \_\_\_\_\_ Fecha: \_\_\_\_ / \_\_\_\_

Integrantes: \_\_\_\_\_

## PIEZA 1 · QUÉ PROTEGE HOY CADA MECANISMO

| AMENAZA | ¿PROTEGE? | POR QUÉ |
|---------|-----------|---------|
|         |           |         |
|         |           |         |
|         |           |         |

## PIEZA 2 · LOS TRES PROBLEMAS DE LA EVIDENCIA C

| PROBLEMA          | QUÉ ESTÁ MAL Y QUÉ CONSECUENCIA TIENE |
|-------------------|---------------------------------------|
| 1 · La llave      |                                       |
| 2 · La derivación |                                       |
| 3 · El modo       |                                       |

Línea corregida: \_\_\_\_\_

## PIEZAS 3 Y 4 · CIFRADO DE CAMPO Y VIABILIDAD

| CAMPO A CIFRAR | POR QUÉ (SENSIBILIDAD + EXPOSICIÓN) | CÓMO SE BUSCA | RESTRICCIÓN Y COSTO |
|----------------|-------------------------------------|---------------|---------------------|
|                |                                     |               |                     |
|                |                                     |               |                     |

## RECUERDEN

Esta hoja es para ordenar el trabajo. La entrega es un documento del equipo con las cuatro piezas, al inicio de la sesión 3. La pieza que más pesa es la 2, y la que más se olvida es «cómo se busca» de la pieza 3.